

WordPress Security Audit Report

Target: Local WordPress Lab (192.168.56.1)

Date: April 2026

Auditor: Ishant Pundir

1. Executive Summary

A security audit was conducted on a WordPress installation hosted in a local lab environment. The objective was to identify vulnerabilities, assess their impact, and implement remediation measures.

Several critical and medium-risk vulnerabilities were discovered, including XML-RPC exposure, user enumeration, and directory listing. After applying security fixes, a follow-up scan confirmed that major risks were successfully mitigated.

2. Scope

- Target: WordPress website (local environment)
 - Tools Used: WPScan
 - Approach: Vulnerability assessment and remediation
-

3. Initial Findings

The initial scan revealed the following vulnerabilities:

- XML-RPC enabled (Critical)
- Default admin username exposed (Critical)
- Directory listing enabled (Medium)
- Server information disclosure (Medium)
- WordPress readme exposed (Low)
- WP-Cron accessible externally (Low)
- Plugin vulnerability (Akismet - potential XSS)

These issues increased the attack surface and exposed the system to brute-force attacks, data leakage, and potential exploitation.

4. Remediation Actions

The following fixes were applied:

- Disabled XML-RPC via server configuration
- Removed default admin account and created a new secure user
- Disabled directory listing using .htaccess
- Removed WordPress readme file
- Reduced server information exposure via Apache configuration

Some issues such as WP-Cron exposure and plugin verification remain pending.

5. Validation (Re-Scan Results)

A follow-up scan was conducted after applying fixes.

Resolved:

- XML-RPC no longer detected
- Directory listing disabled
- Readme file removed
- Default admin user removed

Remaining:

- WP-Cron still accessible
 - User enumeration partially possible
 - Server header partially visible
 - Plugin version not verified
-

6. Risk Assessment

Before remediation:

- High risk due to multiple critical vulnerabilities

After remediation:

- Risk significantly reduced
 - System more secure but not fully hardened
-

7. Conclusion

The audit successfully identified and mitigated major security vulnerabilities, including XML-RPC exposure and the use of a default admin account. These remediation efforts have significantly improved the overall security posture of the WordPress application.

However, complete system hardening still requires addressing several remaining issues, specifically WP-Cron accessibility, partial user enumeration, server header visibility, and unverified plugin versions. Further hardening is recommended to eliminate these residual risks and ensure long-term security.